

PropComply AI Ltd

VerifyMe Global

Complete Technical & Business Requirements Document
BRD · FRD · User Stories · Epics · Tasks · Technical Architecture · GDPR

Version	2.0.1
Date	June 2026
Author	Joy Ladegbaye, Founder & Director
Classification	CONFIDENTIAL
Status	For Review — Innovator Founder Visa Resubmission

1. Executive Overview & Document Purpose

This document provides the complete Business Requirements Document (BRD), Functional Requirements Document (FRD), User Stories, Epics, and Tasks for PropComply AI Ltd's dual-sided platform: PropComply AI (agency-side compliance) and VerifyMe Global (individual-side portable cross-border identity). It also covers full technical architecture, API specifications, database schema, technology stack, MVC structure, and GDPR compliance mapping for every processing activity.

1.1 Problem Statement

Every existing UK property compliance platform (SmartSearch, Thirdfort, Credas, Verify 365) was built for subjects with a UK identity footprint. They depend on UK electoral roll, UK credit reference data, UK address history, and UK-issued documents. This architecture systematically excludes the 900,000+ individuals who arrive in the UK each year without a pre-existing UK identity — not because they are high-risk, but because these platforms were never designed to look at non-UK data sources.

This creates three simultaneous market harms:

- Immigrant tenants and buyers cannot access housing on fair terms — their overseas financial track record, tenancy history, and professional credentials are invisible to the UK market.
- UK estate and letting agents are caught between two legal exposures: rejecting immigrants (Equality Act 2010 race discrimination risk) or accepting them without adequate checks (MLR 2017 AML breach risk).
- The UK property market loses access to its highest-value international demand — the segment that currently has no compliant verification pathway.

1.2 Solution Summary

PropComply AI introduces VerifyMe Global — a Portable Cross-Border Property Identity Network. It is not a feature addition to an existing platform. It is a new market category: a jurisdictional identity translation engine that takes verified evidence of who a person is in their country of origin and converts it into a UK-regulatory-compatible risk profile via Triple-Source Corroboration (Biometric Anchor + Behavioural Financial Pattern + Cross-Jurisdictional Corroboration).

1.3 Document Scope

This document covers:

- Business Requirements Document (BRD) — strategic objectives, stakeholder needs, constraints
- Functional Requirements Document (FRD) — detailed system behaviours, inputs, outputs, rules
- User Personas — all actor types with goals, pain points, and system interactions
- Epics, User Stories, and Tasks — full agile backlog structure
- Technical Architecture — application tiers, technology stack, MVC modular structure
- API Specifications — all internal and external API contracts
- Database Design — schema, entities, relationships, indexes
- GDPR Compliance Matrix — lawful basis, data flows, retention, DPIA triggers

2. Business Requirements Document (BRD)

2.1 Business Objectives

ID	Objective	Success Metric	Timeline
BR-01	Establish PropComply AI as the primary AML/KYC compliance platform for UK estate and letting agents unable to serve non-UK clients compliantly	125 paying agencies by end of Year 1	Year 1
BR-02	Launch VerifyMe Global as the first portable cross-border property identity product in the UK market	500 individual profiles built by end of Year 1	Year 1
BR-03	Eliminate the guarantor requirement for VerifyMe Global Certified individuals, disrupting the exploitative commercial guarantor market	Guarantor Replacement Certificate accepted by 20+ landlords/agencies by Month 12	Year 1
BR-04	Generate Data Intelligence revenue by monetising anonymised, aggregated cross-border behavioural datasets	2 signed Lender Intelligence API contracts by end of Year 2	Year 2
BR-05	Build W3C DID credential infrastructure making VerifyMe Global credentials portable across the EU without central server dependency	5,000 active DID credentials issued by end of Year 2	Year 2
BR-06	Achieve £2.8M ARR by end of Year 3 through all five revenue tiers	Five-tier revenue dashboard operational; £2.8M ARR confirmed	Year 3
BR-07	Establish EU market presence (Germany primary) via modular regulatory engine licensing	GwG-compliant module live; 2 EU platform partners signed	Year 3
BR-08	Position PropComply as the global property compliance infrastructure standard	API licensing to 3+ major PropTech platforms (Reapit, Rightmove, or equivalent)	Year 4-5

2.2 Stakeholder Map

Stakeholder	Role	Interest	Influence
Joy Ladegbaye	Founder & Director	Product delivery, regulatory compliance, Innovator Founder Visa validation	High
UK Estate/Letting Agents	Primary paying B2B customers (Agency SaaS)	Compliant AML/KYC tooling; safe non-UK client onboarding; avoidance of Equality Act and MLR 2017 liability	High
Immigrant Individuals (Tenants/Buyers)	Primary B2C end-users	Portable identity credential; guarantor replacement; fair housing access	High

Stakeholder	Role	Interest	Influence
	(VerifyMe Global)		
Build-to-Rent Operators	Enterprise plan customers	Compliant international professional tenant pipeline	Medium
Mortgage Lenders	Data Intelligence API customers	Non-UK credit signal for international buyer mortgage underwriting	Medium
Property Insurers	Data Intelligence API customers	Cross-border tenant risk intelligence for pricing accuracy	Medium
HMRC / NCA	Regulatory oversight + potential intelligence partner	AML compliance; anonymised cross-border suspicious activity intelligence	High
Home Office / UKVI	Regulatory / data anchor provider	Right to Rent enforcement; visa status verification	High
Source-Country Govts (NGA, IND, RWA)	Database integration partners	Identity verification API access agreements	Medium
Banks / Neobanks	Partner Referral programme payers	Pre-verified immigrant customer acquisition	Low
Technical Advisor	Architecture oversight	Platform scalability, security, and compliance	High
Contracted Developer(s)	Build delivery	Clear specifications, modular build, achievable MVP scope	High

2.3 Business Constraints

Constraint	Description	Impact
Regulatory — MLR 2017	All agency-side AML/KYC functionality must produce outputs compliant with Money Laundering Regulations 2017. PropComply does not replace the agency's MLRO — it provides the tooling.	High
Regulatory — UK GDPR / DPA 2018	All personal data processing must have a documented lawful basis under UK GDPR. Biometric data requires explicit Article 9 consent. Data minimisation and purpose limitation are non-negotiable.	High
Regulatory — Equality Act 2010	The platform must not produce outputs that facilitate or constitute racial discrimination. VerifyMe Global must offer a compliant pathway for non-UK nationals, not a discriminatory exclusion mechanism.	High

Constraint	Description	Impact
Technical — Home Office Data Access	PropComply cannot directly query Home Office immigration records. The visa anchor is corroborated by the individual presenting their BRP/visa documentation, cross-referenced via the Employer Checking Service or HMPO online tool.	Medium
Technical — Biometric Data	Biometric data (live facial scan) must be processed in-memory and not stored persistently. Only the verification result (pass/fail + confidence score) is retained. Requires DPA compliance.	High
Commercial — MVP Scope (Year 1)	Year 1 MVP uses centralised AWS-hosted profiles. W3C DID migration is Year 2. This constrains the portability story for Year 1 but reduces technical risk and time-to-market.	Medium
Financial — Founder-Led Build	Initial build is founder-designed + Technical Advisor oversight + contracted developer execution. Budget constrains simultaneous feature development; strict MVP prioritisation required.	High
Geographic — UK Jurisdiction Primary	Year 1 is exclusively UK market. EU regulatory engine (AMLD6, GwG, TRACFIN) is Year 3. Global expansion (FINTRAC, AUSTRAC) is Year 4-5.	Medium

2.4 Assumptions

- The Home Office does not expose a public API for real-time visa status verification; the BRP/visa document presented by the individual is the primary input, corroborated via HMPO online checking service.
- Nigerian NIBSS, NIN, and BVN APIs are accessible under commercial data sharing agreements in Year 1. Indian Aadhaar API access requires UIDAI partnership agreement (Year 2 target).
- AWS Rekognition is used for biometric matching in Year 1; a proprietary model is trained and deployed in Year 2 using the accumulated verified identity dataset.
- The federated learning consortium requires a minimum of 10 participating agencies before the cross-agency laundering detection model provides meaningful signal uplift.
- GDPR consent management is implemented at the granular level: each data source has a separate consent toggle in the individual's VerifyMe Global onboarding flow.

3. User Personas

Eight distinct personas interact with the PropComply AI + VerifyMe Global platform. Each has distinct goals, pain points, technical literacy levels, and compliance obligations.

Persona 1 — Amara Okafor: Skilled Worker Visa Holder

Attribute	Detail
Name	Amara Okafor
Age	32
Nationality	Nigerian
Current Status	Arrived in UK on Skilled Worker Visa (Software Engineer, NHS Digital). Biometric Residence Permit held.
Housing Need	Seeking 12-month private rental tenancy in London; £1,800/month budget.
Pain Point	No UK credit history, no UK address history, no UK bank account (opened 6 weeks ago). Every agency she approaches either rejects her outright or demands a UK-based guarantor at £450 commercial fee.
Financial Profile (Overseas)	7 years employed at Access Bank Plc, Nigeria. Clean BVN record. Consistent NGN salary deposits for 84 months. Zero derogatory credit events. NIN verified.
Technical Literacy	High — uses banking apps, comfortable with document upload flows.
Primary Goal	Build a VerifyMe Global Certified profile to use as a Guarantor Replacement Certificate; access housing without paying £450 to a commercial guarantor.
Secondary Goal	Have her profile renew automatically each year so she only verifies once for all future property transactions in the UK.
GDPR Sensitivity	Consents to biometric processing at onboarding; wants to review exactly which Nigerian databases are checked before consenting to each.
System Entry Point	VerifyMe Global Individual App (mobile/web) — self-service onboarding flow.

Persona 2 — David Adeyemi: International Student

Attribute	Detail
Name	David Adeyemi
Age	24
Nationality	Nigerian (Tier 4 Student Visa, UCL)
Housing Need	Student house share; £900/month contribution. Needs to sign tenancy within 2 weeks (term start pressure).
Pain Point	No UK credit history; parents in Nigeria willing to act as guarantors but are overseas. Agency requires UK-based guarantor. Commercial guarantor firms require UK bank account proof, which he doesn't yet have.
Financial Profile	Parents' BVN and NIN verified; parental bank statements show consistent savings. WAEC/NECO academic certificates verified at UCAS stage.
Technical Literacy	Very high — digital native.

Attribute	Detail
Primary Goal	Obtain Express Verification (48-hour) VerifyMe Global profile to meet tenancy deadline.
System Entry Point	VerifyMe Global mobile app; Express Verification add-on checkout.

Persona 3 — Elena Vasquez: EU National (Post-Brexit)

Attribute	Detail
Name	Elena Vasquez
Age	38
Nationality	Spanish (EU Settlement Scheme — Pre-Settled Status)
Housing Need	Buying a 2-bedroom flat in Manchester; £285,000 purchase. Needs AML/KYC compliance from estate agent.
Pain Point	Her Spanish bank account (Santander ES) and 15-year financial history in Spain are completely invisible to UK AML tools. Agent is unsure how to verify her compliantly without a UK footprint.
Financial Profile	15 years Santander Spain account; PSD2 Open Banking available. EUSS pre-settled status BRP. Clean Spanish credit record.
Technical Literacy	Medium — comfortable with web but not specialist financial apps.
Primary Goal	Complete VerifyMe Global profile using PSD2 Open Banking to supply her Spanish financial history; receive VerifyMe Global Certified credential for estate agent.
GDPR Note	Strong GDPR awareness; wants to understand exactly what data is shared with the estate agent before proceeding.
System Entry Point	VerifyMe Global web portal; EU Open Banking (PSD2) integration flow.

Persona 4 — James Whitfield: Estate Agent (MLRO)

Attribute	Detail
Name	James Whitfield
Age	45
Role	Director and designated Money Laundering Reporting Officer (MLRO), independent 8-branch estate agency, South London.
Pain Point	Receives 15-20 applications per month from non-UK nationals. His current AML tool (SmartSearch) returns 'no identity found' for most of them. He either manually processes overseas documents (time-consuming, error-prone, legally ambiguous) or refers them elsewhere, losing commission and risking Equality Act exposure.
Compliance Obligations	MLR 2017 — AML/KYC on all clients. Right to Rent checks. HMRC AML supervision. SAR filing to NCA when required.
Technical Literacy	Medium — uses CRM (Reapit), email, basic web tools.
Primary Goal	Receive a compliant, auditable, defensible risk signal for non-UK clients via PropComply; eliminate manual overseas document processing.

Attribute	Detail
Secondary Goal	Automate Right to Rent checks; auto-generate SAR drafts for high-risk cases; have Hyperledger audit trail available for HMRC inspection.
System Entry Point	PropComply AI Agency Dashboard — web portal. Reapit CRM integration.

Persona 5 — Sarah Chen: Build-to-Rent Operations Manager

Attribute	Detail
Name	Sarah Chen
Age	41
Role	Operations Manager, large Build-to-Rent operator (500+ units, 3 London sites).
Pain Point	BTR actively wants to fill units with international professional tenants (tech workers, finance professionals, academics). No current tool allows compliant bulk onboarding of verified international applicants. High application dropout rate due to verification failure.
Primary Goal	Access PropComply Enterprise API to embed VerifyMe Global pre-verification into BTR application portal; receive pre-verified profiles as structured data.
Secondary Goal	Real-time dashboard of international applicant pipeline; automated Right to Rent; bulk export of compliance records for investor reporting.
System Entry Point	PropComply Enterprise API (B2B integration); BTR Operations Dashboard.

Persona 6 — Mohammed Al-Rashid: International Property Buyer

Attribute	Detail
Name	Mohammed Al-Rashid
Age	52
Nationality	UAE national; no UK visa (visitor entry for property purchase)
Transaction	Purchasing prime London property (£1.8M). No UK visa — no Home Office anchor available.
Pain Point	Estate agent cannot complete EDD (Enhanced Due Diligence) using UK-centric tools. Manual source of funds check is laborious; agent unfamiliar with UAE financial documentation.
Financial Profile	UAE National ID; 20 years Emirates NBD account; property portfolio declared; source of wealth: business dividends (Al-Rashid Trading LLC, Dubai DED registered).
Primary Goal	Complete VerifyMe Global profile using full Triple-Source Engine without Home Office anchor; receive EDD-compatible compliance package for estate agent.
System Entry Point	VerifyMe Global web portal — international buyer pathway. No Home Office anchor; higher weight on biometric + financial behavioural corroboration.

Persona 7 — Compliance Officer at Mortgage Lender (Data Intelligence API Consumer)

Attribute	Detail
Name	Rachel Thompson
Age	48
Role	Chief Compliance Officer, mid-tier mortgage lender with international buyer product.
Pain Point	40% of prime mortgage applications involve non-UK buyers. Credit scoring models have no signal for international buyers — the bank either accepts with inadequate risk assessment or rejects, losing high-value business.
Primary Goal	Access PropComply Lender Intelligence API to supplement international buyer mortgage underwriting with anonymised cross-border behavioural signals.
GDPR Note	Data received must be fully anonymised and aggregated (k-anonymity ≥ 50). No PII. Data Processing Agreement required. ICO re-identification risk assessment documented.
System Entry Point	PropComply Lender Intelligence API (REST, JSON); dashboard reporting portal.

Persona 8 — PropComply Platform Administrator

Attribute	Detail
Name	Internal — PropComply Operations Team
Role	Platform administration, GDPR data subject request handling, partner API key management, Hyperledger node monitoring.
Primary Goals	Monitor platform health; manage agency onboarding; handle data subject access requests (DSAR); review flagged verification cases; manage country database integration status; issue and revoke W3C DID credentials.
System Entry Point	PropComply Admin Portal (internal; MFA-protected; role-based access control).

4. Functional Requirements Document (FRD)

Functional requirements are organised by module. Each requirement carries an ID, priority (Must Have / Should Have / Could Have / Won't Have this release — MoSCoW), and GDPR flag where data processing is involved.

4.1 Module 1 — Agency Onboarding & Authentication

FR ID	Requirement	Priority	GDPR Flag
FR-AO-01	The system shall allow an estate or letting agent organisation to self-register via a web form capturing: legal entity name, Companies House number, FCA/HMRC supervisor reference, designated MLRO name and email, and billing contact.	Must Have	Art. 6(1)(b) — Contract
FR-AO-02	The system shall verify the Companies House number against the Companies House API and display the registered entity name for confirmation before activating the account.	Must Have	No personal data
FR-AO-03	The system shall require email verification (tokenised link, 24-hour expiry) before granting portal access.	Must Have	Art. 6(1)(b)
FR-AO-04	The system shall enforce Multi-Factor Authentication (MFA) for all agency user accounts via TOTP (Google Authenticator / Authy) or SMS OTP.	Must Have	Security measure
FR-AO-05	The system shall support role-based access control within an agency account: Admin, MLRO, Compliance Officer, Standard User. Each role has defined read/write permissions on CDD files, SAR drafts, and billing.	Must Have	Art. 5(1)(f) — Security
FR-AO-06	The system shall log all user authentication events (login, logout, failed attempt, MFA bypass) with timestamp, IP address, and user agent. Logs retained for 24 months.	Must Have	Art. 5(2) — Accountability
FR-AO-07	The system shall allow an agency Admin to invite additional users by email and assign roles. Invitations expire after 72 hours.	Must Have	Art. 6(1)(b)
FR-AO-08	The system shall allow an agency Admin to deactivate a user account. Deactivation does not delete audit logs associated with that user.	Must Have	Art. 17 — Right to erasure (limited by audit requirements)

4.2 Module 2 — AML/KYC Risk Scoring Engine (Agency-Side)

FR ID	Requirement	Priority	GDPR Flag
FR-AML-01	The system shall allow an agency user to initiate a new client AML/KYC check by entering: full name, date of birth, nationality, document type, document number, and transaction type (rental / purchase / sale).	Must Have	Art. 6(1)(b)

FR ID	Requirement	Priority	GDPR Flag
FR-AML-02	For UK-footprint clients, the system shall query UK electoral roll, Experian/Equifax/TransUnion credit data, CIFAS fraud database, and address history. All queries must be logged with timestamp and data source.	Must Have	Art. 6(1)(b); Schedule 2 DPA 2018
FR-AML-03	For non-UK clients, the system shall route to the VerifyMe Global Triple-Source Engine rather than returning a 'no data found' result. The routing must be automatic and transparent to the agency user.	Must Have	Art. 6(1)(a) — Individual consent required
FR-AML-04	The system shall screen every client against OFAC, HM Treasury Consolidated List, UN Consolidated List, and EU Sanctions List for PEP and sanctions status. Screening must complete within 10 seconds.	Must Have	Art. 6(1)(c) — Legal obligation
FR-AML-05	The system shall output a composite risk score (0–100) and risk tier (Low / Medium / High / Refer) with an explainability narrative of the top 5 contributing factors.	Must Have	Art. 22 — Automated decision-making safeguards apply
FR-AML-06	High-risk scores (≥ 70) shall automatically trigger an Enhanced Due Diligence (EDD) workflow, notify the MLRO, and lock the client file from approval until MLRO review is recorded.	Must Have	Art. 6(1)(c)
FR-AML-07	The system shall support source of funds document upload (bank statements, payslips, gift letters, company accounts). Accepted formats: PDF, JPEG, PNG. Maximum 25MB per document. OCR parsing extracts key figures for coherence scoring.	Must Have	Art. 6(1)(b)
FR-AML-08	The system shall present the agency user with a regulatory disclosure: 'This score is an aid to your AML/KYC decision. As the regulated entity, you remain responsible for all MLR 2017 compliance obligations.' User must acknowledge before viewing the score.	Must Have	Liability management
FR-AML-09	Risk scores shall be recalculated automatically when: (a) new documents are uploaded, (b) the VerifyMe Global profile is updated, (c) a sanctions list update is detected, or (d) 12 months have elapsed since last check.	Must Have	Art. 5(1)(d) — Accuracy
FR-AML-10	The system shall support property-specific risk weighting: transaction value above £75,000 increases the base risk score by 10 points; commercial property adds 5 points; prime London postcode (SW1, W1, WC2, EC1-4) adds 5 points.	Should Have	No additional GDPR flag

4.3 Module 3 — Customer Due Diligence (CDD) Workflow

FR ID	Requirement	Priority	GDPR Flag
FR-CDD-01	The system shall present three CDD pathways based on risk score: Standard CDD (score < 40), Enhanced Due Diligence (score ≥ 70 or PEP flag), and Simplified Due Diligence (rule-based low-risk categories). Pathway selection is automatic with override capability for MLRO.	Must Have	Art. 6(1)(b)

FR ID	Requirement	Priority	GDPR Flag
FR-CDD-02	Standard CDD checklist: identity document verified, PEP/sanctions screened, risk score recorded, business relationship purpose documented. All items must be checked before the CDD file is marked Complete.	Must Have	MLR 2017 Reg. 28
FR-CDD-03	EDD additional requirements: source of wealth narrative (minimum 200 characters), senior management sign-off recorded in system, enhanced sanctions screening against 50+ additional lists, 24-month financial history analysis.	Must Have	MLR 2017 Reg. 33
FR-CDD-04	The system shall allow an agency user to invite a client to complete a self-service data submission via a tokenised secure link (expiry 7 days). Client submits documents; agency reviews and approves.	Must Have	Art. 6(1)(b)
FR-CDD-05	CDD files shall be retained for 5 years from the end of the business relationship, then automatically scheduled for deletion unless a legal hold is placed by the MLRO. Deletion is logged on Hyperledger.	Must Have	MLR 2017 Reg. 40; Art. 5(1)(e)
FR-CDD-06	The system shall display a CDD completion dashboard showing: total active clients, CDD due for renewal, EDD cases pending MLRO sign-off, and overdue re-checks by branch.	Should Have	No additional flag

4.4 Module 4 — SAR Filing Engine

FR ID	Requirement	Priority	GDPR Flag
FR-SAR-01	The system shall generate a pre-populated SAR draft when a risk score exceeds 80 or the MLRO manually triggers a SAR from a client file. Draft includes: subject details (from CDD file), nature of suspicion, supporting document references, and MLRO declaration fields.	Must Have	Art. 6(1)(c) — Legal obligation; tipping-off prevention applies
FR-SAR-02	The SAR draft shall comply with UKFIU SAR Online submission format. The system shall submit the SAR via the NCA SARs Online API and store the acknowledgement reference number in the client file.	Must Have	Art. 6(1)(c)
FR-SAR-03	The system shall enforce tipping-off prevention: once a SAR is drafted or submitted, the client file is locked and no automated communications to the client may be sent from that file. MLRO is notified.	Must Have	POCA 2002 s.333A
FR-SAR-04	Where NCA consent to proceed (CTP) is required, the system shall track CTP request status and alert the agency before any consent deadline expires.	Must Have	POCA 2002 s.335
FR-SAR-05	The system shall record all SAR-related events on the Hyperledger audit trail: draft created, MLRO reviewed, submitted, NCA reference received, CTP status. Events are immutable.	Must Have	Art. 5(2) — Accountability

4.5 Module 5 — Right to Rent Automation

FR ID	Requirement	Priority	GDPR Flag
FR-RTR-01	The system shall support Right to Rent verification for all document types accepted by the Home Office: UK/Irish passport, BRP, EU Settlement Scheme status, eVisa, and share code verification.	Must Have	Art. 6(1)(c)
FR-RTR-02	For non-UK documents, the system shall classify the Right to Rent status as: Unlimited (no follow-up), Time-Limited (follow-up required before expiry), or No Right to Rent. Classification logic based on current UKVI guidance.	Must Have	Immigration Act 2014
FR-RTR-03	The system shall integrate with the HMPO online document checking service for UK passport verification and the UKVI share code service for digital immigration status verification.	Must Have	Art. 6(1)(c)
FR-RTR-04	For time-limited Right to Rent, the system shall create automated reminders at 90, 60, and 30 days before the document expiry date, sent to the responsible agent's email and in-portal inbox.	Must Have	Art. 6(1)(b)
FR-RTR-05	The system shall generate a timestamped, agent-signed Right to Rent compliance record for every check performed, stored in the CDD file and on the Hyperledger audit trail. This record is the legal evidence of the check performed.	Must Have	Immigration Act 2014 s.22
FR-RTR-06	For VerifyMe Global Certified individuals, the Right to Rent check shall be pre-populated from the verified profile, requiring only agent confirmation and signature. Processing time target: <2 minutes.	Must Have	Art. 6(1)(b)

4.6 Module 6 — VerifyMe Global Individual Onboarding

FR ID	Requirement	Priority	GDPR Flag
FR-VMG-01	The system shall provide an individual-facing onboarding flow (web and mobile) in English as primary language, with document capture interfaces optimised for mobile camera upload.	Must Have	Art. 6(1)(a) — Consent
FR-VMG-02	At onboarding, the system shall present a granular consent dashboard showing each data source to be checked (biometric, bank statements, specific overseas government databases) with individual opt-in/opt-out toggles. The consent dashboard must be presented before any data collection begins.	Must Have	Art. 7 — Conditions for consent; Art. 9(2)(a) — Biometric
FR-VMG-03	Biometric liveness check: the system shall present an active liveness challenge (minimum 3 of: blink, head turn left, head turn right, smile). Challenge must be completed within 60 seconds. Failure triggers a retry (maximum 3 attempts).	Must Have	Art. 9(2)(a) — Explicit consent; data deleted post-check
FR-VMG-04	Document capture: the system shall accept passport (biometric chip or photograph), national identity card, or BRP. MRZ is extracted and validated. Document authenticity check (hologram, UV pattern simulation) is performed. Accepted: JPEG, PNG, PDF. Max 10MB.	Must Have	Art. 6(1)(a)

FR ID	Requirement	Priority	GDPR Flag
FR-VMG-05	Bank statement analysis: the system shall accept 24 months of bank statements in PDF format from any institution. OCR extracts transactions. Analysis produces: income regularity score, spending coherence score, savings trajectory, and fabricated history anomaly flags.	Must Have	Art. 6(1)(a)
FR-VMG-06	For EU/EEA nationals: the system shall offer PSD2 Open Banking consent flow as an alternative to statement upload. Supported banks: any PSD2-compliant institution. The bank-supplied transaction data carries higher corroboration weight than self-supplied documents.	Must Have	Art. 6(1)(a)
FR-VMG-07	Home Office anchor: the system shall prompt the individual to confirm their UK visa type and input their BRP number and visa expiry. The HMPO checking service or Employer Checking Service is queried to confirm validity.	Must Have	Art. 6(1)(a); Art. 6(1)(c)
FR-VMG-08	Source-country government database check: the system shall query the applicable database (NIBSS/NIN Nigeria, Aadhaar India, NIDA Rwanda) with individual consent. Individual is shown which database will be queried and what data will be retrieved before confirmation.	Must Have	Art. 6(1)(a)
FR-VMG-09	The Triple-Source Fusion Engine shall compute a composite confidence score (0–100) from the three layers with configurable weights. Score is displayed to the individual with a plain-language explanation of each component's contribution.	Must Have	Art. 22 — Automated decision-making
FR-VMG-10	A VerifyMe Global Certified credential (score ≥80) shall be issued within 4 hours of all data submission for standard verification, and within 48 hours for Express Verification pathway.	Must Have	SLA commitment
FR-VMG-11	The individual shall be able to share their credential with a specific agency user by entering the agency's PropComply ID. Sharing creates a time-limited (90-day) view permission for the agency user. The individual can revoke at any time.	Must Have	Art. 6(1)(a) — Consent; Art. 17 — Right to erasure
FR-VMG-12	The Guarantor Replacement Certificate shall be a downloadable PDF document containing: individual name, VerifyMe Global certification reference number, confidence score band, key corroboration signals confirmed, PropComply contact for verification, and expiry date (12 months from issuance).	Must Have	Art. 6(1)(b)

4.7 Module 7 — Blockchain Audit Trail (Hyperledger Fabric)

FR ID	Requirement	Priority	GDPR Flag
FR-HL-01	The system shall record every compliance event on a Hyperledger Fabric permissioned blockchain. Events include: CDD initiated, document uploaded, risk score calculated, SAR drafted, SAR submitted, Right to Rent check performed, VerifyMe Global credential issued, credential shared, CDD file deleted.	Must Have	Art. 5(2) — Accountability

FR ID	Requirement	Priority	GDPR Flag
FR-HL-02	Each blockchain record shall contain: event type, timestamp (UTC), actor ID (agency user or individual), client/individual reference hash (not raw PII), event hash, and previous block hash. PII must not be stored on-chain.	Must Have	Art. 25 — Privacy by design
FR-HL-03	The system shall support Zero-Knowledge Proof (ZKP) generation allowing an agency to prove to HMRC that a specific compliance check was performed on a specific date without revealing the client's identity.	Should Have	Art. 5(1)(c) — Data minimisation
FR-HL-04	Hyperledger nodes shall be operated by PropComply on AWS infrastructure (minimum 3 nodes for fault tolerance). Node health status shall be visible on the Admin Portal.	Must Have	Art. 32 — Security

4.8 Module 8 — Data Intelligence API (Year 2)

FR ID	Requirement	Priority	GDPR Flag
FR-DI-01	The Lender Intelligence API shall return anonymised, aggregated cross-border financial behaviour signals. Minimum aggregation: k-anonymity $k \geq 50$ (no single data point traceable to fewer than 50 individuals). API response includes: income regularity index by nationality/occupation band, rent payment completion rate by property type, default event frequency by source country.	Should Have (Year 2)	Art. 6(1)(f) — Legitimate interests; anonymisation removes personal data status
FR-DI-02	Before the Lender Intelligence API is activated, a Data Protection Impact Assessment (DPIA) must be completed and documented, confirming that the aggregated outputs cannot be re-identified against any external dataset held by the API consumer.	Must Have (Year 2)	Art. 35 — DPIA required
FR-DI-03	API consumers must sign a Data Processing Agreement (DPA) prohibiting: use of the data to identify individuals, combining with other datasets for re-identification, onward transfer to third parties, and use for automated individual-level decision-making.	Must Have (Year 2)	Art. 28 — Processor obligations
FR-DI-04	The HMRC/NCA anonymised intelligence feed shall provide: monthly aggregated suspicious transaction pattern reports by property segment, anonymised red flag indicators detected by PropComply's AML engine, and trend analysis of cross-border transaction patterns. No individual-level data. Governed by formal public authority data sharing agreement.	Could Have (Year 2)	Art. 6(1)(c) — Legal obligation; s.7 DPA 2018

5. Epics, User Stories & Tasks

The backlog is organised into 9 Epics covering the full platform. User Stories follow the format: 'As a [persona], I want [goal] so that [outcome]'. Tasks are the atomic development units beneath each story.

EPIC 1 — Agency Authentication & Onboarding

Epic Goal

Enable any UK-registered estate or letting agency to self-onboard onto PropComply AI, verify their identity, and configure their account within 30 minutes.

ID	User Story	Acceptance Criteria	Points
US-01	As an agency Admin (James), I want to register my agency by entering our Companies House number so that our legal entity is automatically verified without manual paperwork.	Companies House API returns entity name within 3 seconds; admin confirms match; account is created with Pending status until email verified.	5
US-02	As an agency Admin, I want to set up MFA on my account so that unauthorised access is prevented even if my password is compromised.	TOTP QR code presented; backup codes provided; MFA required on all subsequent logins; login without MFA returns 401.	3
US-03	As an agency Admin, I want to invite my MLRO and compliance officers with specific role permissions so that each team member can only access the data relevant to their role.	Invite email sent within 60 seconds; role selector shown on invite; invited user cannot access MLRO-only functions until role confirmed.	5
US-04	As an agency MLRO (James), I want to view an audit log of all actions taken by my team in the platform so that I can demonstrate oversight to HMRC during an inspection.	Audit log shows user ID, action, timestamp, IP; filterable by user and date range; exportable as CSV; log entries are immutable.	5

Task ID	Task	Assignee	Est. Hours	Dependencies
T-01-01	Build agency registration form: legal name, Companies House no., MLRO email, billing contact	Developer	8	—
T-01-02	Integrate Companies House REST API v3 for entity verification	Developer	6	T-01-01
T-01-03	Implement email verification flow with tokenised link (JWT, 24h expiry)	Developer	4	T-01-01
T-01-04	Implement TOTP-based MFA using speakeasy library; QR code generation	Developer	8	T-01-03
T-01-05	Build RBAC model: Admin, MLRO, Compliance Officer, Standard User roles with permission matrix	Developer	10	T-01-03

Task ID	Task	Assignee	Est. Hours	Dependencies
T-01-06	Build user invitation flow with role assignment and 72-hour expiry	Developer	6	T-01-05
T-01-07	Build audit log table (PostgreSQL); log middleware on all API routes; read-only API endpoint for log retrieval	Developer	8	T-01-05
T-01-08	GDPR: Implement consent record storage for agency data processing terms at registration	Developer	4	T-01-01

EPIC 2 — AML/KYC Risk Scoring Engine

Epic Goal

Deliver a property-specific AML/KYC risk engine that produces a defensible, explainable risk score for any client — UK or non-UK — in under 30 seconds.

ID	User Story	Acceptance Criteria	Points
US-05	As an agency compliance officer, I want to initiate a new client check by entering basic details so that the system automatically selects the correct verification pathway.	Form captures name, DOB, nationality, document type, transaction type; submission triggers routing logic; non-UK nationality automatically routes to VerifyMe Global pathway.	8
US-06	As an agency MLRO (James), I want to receive an automatic EDD flag when a client scores above 70 so that I review every high-risk case before it proceeds.	Score ≥ 70 triggers EDD workflow; MLRO email notification within 60 seconds; client file locked from approval until MLRO records review decision.	8
US-07	As an agency user, I want to upload source of funds documents and have the system extract key financial figures so that I don't have to manually transcribe bank statement data.	PDF upload accepted; OCR processes within 90 seconds; income total, largest transactions, and counterparty names extracted and displayed for review.	13
US-08	As an agency user, I want the risk score to clearly explain which factors contributed most so that I can articulate my compliance decision to HMRC.	Risk score displays top 5 contributing factors with weighting; explainability text in plain English; exportable as part of the CDD record.	8

Task ID	Task	Assignee	Est. Hours	Dependencies
T-02-01	Build client check initiation API: POST /api/v1/checks — validation, nationality routing logic	Developer	8	—
T-02-02	Integrate Experian/Equifax/TransUnion sandbox APIs for UK credit reference lookups	Developer	12	T-02-01

Task ID	Task	Assignee	Est. Hours	Dependencies
T-02-03	Integrate CIFAS fraud database API	Developer	8	T-02-01
T-02-04	Build PEP/Sanctions screening: integrate OFAC, HM Treasury, UN lists via Comply Advantage or World-Check API	Developer	10	T-02-01
T-02-05	Build risk scoring algorithm: weighted composite model with property-specific adjustments	Developer	16	T-02-02, T-02-03, T-02-04
T-02-06	Build explainability engine: top-N factor extraction from score components	Developer	8	T-02-05
T-02-07	Build EDD trigger workflow: score threshold check → MLRO notification → file lock	Developer	8	T-02-05
T-02-08	Build document upload API + AWS S3 storage with server-side encryption (SSE-S3)	Developer	6	—
T-02-09	Integrate AWS Textract for OCR of bank statements; parse income and transaction data	Developer	12	T-02-08
T-02-10	GDPR: Implement automated decision-making disclosure (Art. 22) in score display UI	Developer	3	T-02-05

EPIC 3 — VerifyMe Global Individual Onboarding

Epic Goal

Enable any non-UK individual to build a VerifyMe Global Certified profile in a single guided session, with granular GDPR consent at every data collection step.

ID	User Story	Acceptance Criteria	Points
US-09	As an immigrant individual (Amara), I want to see exactly which databases will be checked about me before I agree to anything so that I can make an informed consent decision.	Consent dashboard shows each data source with description, purpose, and retention period. Individual toggles consent per source. No data collection occurs until consent is confirmed.	13
US-10	As an immigrant individual (Amara), I want to complete a biometric liveness check on my phone so that my identity is anchored to my physical presence, not just my documents.	Liveness challenge presented; 3 of 4 gestures required; result returned in <5 seconds; biometric data deleted from processing system within 60 seconds of result; individual receives confirmation.	13
US-11	As an EU national (Elena), I want to connect my Spanish bank account via Open Banking so that my 15-year financial history is verified directly	PSD2 OAuth flow initiated; bank authorises; 24 months of transactions retrieved; coherence score calculated; higher corroboration weight applied vs. document upload.	13

ID	User Story	Acceptance Criteria	Points
	from the bank rather than through self-supplied documents.		
US-12	As an international student (David), I want to pay for Express Verification and receive my credential within 48 hours so that I can meet my tenancy application deadline.	Express Verification checkout; Stripe payment confirmed; verification queue priority flag set; credential issued within 48 hours; email notification sent.	8
US-13	As an immigrant individual (Amara), I want to share my VerifyMe Global credential with a specific estate agency so that they can view my verified profile without me having to submit documents again.	Individual enters agency PropComply ID; 90-day view permission created; agency user receives notification; individual sees active share list and can revoke at any time.	8
US-14	As an immigrant individual (Amara), I want to download my Guarantor Replacement Certificate as a PDF so that I can present it to my landlord instead of paying a commercial guarantor.	Certificate generated as PDF with all required fields; download available within 24 hours of certification; certificate has 12-month validity with PropComply verification URL.	5

Task ID	Task	Assignee	Est. Hours	Dependencies
T-03-01	Build VerifyMe Global onboarding multi-step wizard (React SPA): consent → document → biometric → financial → government DB → review	Developer	20	—
T-03-02	Build granular consent dashboard with per-source toggle, purpose text, and consent record storage (PostgreSQL consent_records table)	Developer	10	T-03-01
T-03-03	Integrate AWS Rekognition for liveness detection and face matching; implement in-memory-only biometric processing with 60-second post-result deletion	Developer	16	T-03-01
T-03-04	Build document capture module: MRZ extraction (passport-reader lib), hologram detection heuristics, document classification	Developer	12	T-03-01
T-03-05	Build bank statement analysis engine: PDF OCR → transaction extraction → coherence scoring algorithm	Developer	16	T-03-01
T-03-06	Integrate Open Banking (PSD2) via TrueLayer or Plaid Europe: OAuth flow, consent management, 24-month transaction retrieval	Developer	14	T-03-01
T-03-07	Integrate NIBSS/NIN API (Nigeria): API agreement, credential storage	Developer	12	T-03-01

Task ID	Task	Assignee	Est. Hours	Dependencies
	in AWS Secrets Manager, query flow, result mapping			
T-03-08	Build Home Office anchor module: BRP number capture, HMPO checking service integration	Developer	8	T-03-01
T-03-09	Build Triple-Source Fusion Engine: weighted score calculator, configurable weights per nationality/visa type, threshold logic	Developer	14	T-03-05, T-03-06, T-03-07, T-03-08
T-03-10	Build credential issuance: generate VerifyMe Global Certified profile record; store in AWS RDS (PostgreSQL)	Developer	8	T-03-09
T-03-11	Build Guarantor Replacement Certificate PDF generator (PDFKit or Puppeteer); S3 signed URL for secure download	Developer	8	T-03-10
T-03-12	Build credential sharing flow: individual enters agency ID → create share_permissions record → agency notification	Developer	8	T-03-10
T-03-13	Integrate Stripe for payment processing: profile build £149, renewal £49, express £49, guarantor certificate £99	Developer	8	T-03-01
T-03-14	GDPR: Implement right to erasure endpoint DELETE /api/v1/individuals/{id}; anonymise verification event on Hyperledger; test data deletion cascade	Developer	10	T-03-10

EPIC 4 — Right to Rent Automation

Epic Goal

Automate Right to Rent verification for UK and non-UK tenants, produce a legally compliant evidence record, and alert agents before time-limited permissions expire.

ID	User Story	Acceptance Criteria	Points
US-15	As an agency user (James), I want the system to automatically classify the Right to Rent status of a tenant's document so that I know immediately whether they have an unlimited or time-limited right.	Document scanned and classified within 30 seconds; status shown as Unlimited / Time-Limited (with expiry date) / No Right to Rent; classification basis displayed.	8
US-16	As an agency MLRO (James), I want to receive automated reminders 90, 60, and 30 days before a time-limited Right to Rent expires so that I never	Reminder schedule created on Right to Rent completion; emails sent at correct intervals; in-portal notification visible; MLRO can acknowledge and record re-check completion.	5

ID	User Story	Acceptance Criteria	Points
	miss a re-check and incur a £3,000 fine.		
US-17	As an agency user, I want the Right to Rent check for a VerifyMe Global Certified individual to be pre-populated from their profile so that I only need to confirm and sign rather than re-collect documents.	VerifyMe Global profile lookup via individual's credential reference; visa type, BRP number, and expiry pre-filled; agent confirms and signs; check completed in <2 minutes.	5

Task ID	Task	Assignee	Est. Hours	Dependencies
T-04-01	Build Right to Rent check workflow: document type selector, HMPO integration, share code integration, status classification engine	Developer	16	—
T-04-02	Build reminder scheduler: cron job queries time-limited_rtr table daily; sends email at 90/60/30-day intervals via AWS SES	Developer	8	T-04-01
T-04-03	Build compliance record generator: timestamped PDF record of check performed, agent signature capture, Hyperledger write	Developer	8	T-04-01
T-04-04	Build VerifyMe Global pre-population integration: GET /api/v1/verifyme/{credential_id}/rtr-data endpoint	Developer	6	T-03-10

EPIC 5 — SAR Filing Engine

Epic Goal

Enable MLROs to draft, review, and submit SARs to the NCA compliantly, with tipping-off prevention and full Hyperledger audit trail.

ID	User Story	Acceptance Criteria	Points
US-18	As an MLRO (James), I want the system to auto-draft a SAR when a risk score exceeds 80 so that I have a pre-populated starting point that reduces drafting time from hours to minutes.	Auto-draft generated within 60 seconds of threshold breach; includes subject details (from CDD), nature of suspicion narrative, supporting document references; MLRO must edit and approve before submission.	8
US-19	As an MLRO, I want the system to submit the approved SAR to NCA and store the acknowledgement reference so that I have proof of submission in the client file.	SAR submitted via NCA API; acknowledgement reference stored in client file; submission timestamp recorded on Hyperledger; MLRO receives email confirmation.	8

Task ID	Task	Assignee	Est. Hours	Dependencies
T-05-01	Build SAR draft generator: NLP template population from CDD data fields; UKFIU format compliance	Developer	12	—
T-05-02	Integrate NCA SARs Online API (SOAP/REST per UKFIU specification); handle authentication and error responses	Developer	10	T-05-01
T-05-03	Implement tipping-off prevention: file lock on SAR draft creation; disable client communications from locked file	Developer	6	T-05-01
T-05-04	Build CTP tracking: status field on SAR record; deadline alert via email and in-portal notification	Developer	4	T-05-02

EPIC 6 — Blockchain Audit Trail

Epic Goal

Record every compliance event on Hyperledger Fabric in an immutable, privacy-preserving audit trail that satisfies HMRC inspection requirements.

ID	User Story	Acceptance Criteria	Points
US-20	As an agency MLRO, I want every compliance action in the system to be recorded on an immutable blockchain so that I can produce an unimpeachable audit trail for HMRC within minutes.	All 9 defined event types written to Hyperledger on occurrence; events are irreversible; HMRC export generates a signed audit report with block hashes.	13
US-21	As an agency MLRO, I want to generate a Zero-Knowledge Proof that a specific check was performed without revealing the client's identity so that I can satisfy regulatory enquiries without disclosing PII.	ZKP generation available from audit log UI; proof file downloadable; verification instructions provided; proof mathematically validates check occurrence without revealing actor identity.	13

Task ID	Task	Assignee	Est. Hours	Dependencies
T-06-01	Deploy Hyperledger Fabric network on AWS: 3 orderer nodes, 2 peer nodes, TLS certificates	Technical Advisor	24	—
T-06-02	Write Hyperledger chaincode (Go): event_type, timestamp, actor_hash, entity_hash, event_hash, prev_hash	Developer	16	T-06-01
T-06-03	Build Hyperledger write middleware: intercept all compliance events in Node.js service layer; async write to Fabric	Developer	10	T-06-02

Task ID	Task	Assignee	Est. Hours	Dependencies
T-06-04	Build audit log read API: GET /api/v1/audit/{entityId}; format for export as signed PDF report	Developer	8	T-06-03
T-06-05	Research and prototype ZKP implementation (zk-SNARKs via snarkjs); integrate with audit log (Year 2 if prototype successful)	Technical Advisor	40	T-06-03

EPIC 7 — Agency Compliance Dashboard

Epic Goal

Give agency users and MLROs a real-time overview of their compliance posture, pending tasks, and key risk metrics.

ID	User Story	Acceptance Criteria	Points
US-22	As an agency MLRO, I want a dashboard showing all CDD cases due for renewal in the next 30 days so that I can manage the re-verification workload proactively.	Dashboard widget shows count of renewals due in 0-30, 31-60, 61-90 day bands; clicking through lists cases with client name (hashed for non-MLRO users), due date, and last check status.	5
US-23	As an agency Admin, I want to see subscription usage metrics (checks consumed, storage used, API calls remaining) so that I can manage our plan and avoid overage charges.	Usage dashboard updates daily; shows current period consumption vs. plan limit; alert at 80% usage; link to upgrade plan.	5

Task ID	Task	Assignee	Est. Hours	Dependencies
T-07-01	Build agency dashboard React components: CDD renewal widget, SAR status widget, Right to Rent expiry widget, usage metrics widget	Developer	20	—
T-07-02	Build dashboard data API: GET /api/v1/agency/dashboard — aggregated from CDD, RTR, SAR tables	Developer	10	—
T-07-03	Build Stripe subscription usage metering integration: track API calls and check volume per billing period	Developer	8	T-01-01

EPIC 8 — Data Intelligence API (Year 2)

Epic Goal

Monetise PropComply's aggregated anonymised dataset by exposing a Lender Intelligence API and Insurer Risk Signal Feed to B2B partners.

ID	User Story	Acceptance Criteria	Points
US-24	As a mortgage lender compliance officer (Rachel), I want to query PropComply's anonymised cross-border financial behaviour data via an API so that I can supplement my international buyer mortgage underwriting model.	API returns aggregated signals (income regularity index, rent payment completion rate) for a given nationality/occupation band; k-anonymity ≥ 50 confirmed in response metadata; data is read-only, no PII returned.	21
US-25	As a PropComply admin, I want to manage partner API keys, set rate limits, and view usage analytics so that I can enforce Data Processing Agreement obligations and detect misuse.	Admin portal shows partner key list, last-used timestamp, daily call volume; rate limit configurable per partner; key revocation immediate.	8

Task ID	Task	Assignee	Est. Hours	Dependencies
T-08-01	Design anonymisation pipeline: aggregate verification data by nationality/occupation/property-type bands; apply k-anonymity ($k \geq 50$); schedule nightly batch job	Developer	16	—
T-08-02	Build Lender Intelligence API: GET /api/v1/intelligence/lender — query by nationality_band, occupation_band, property_type; return aggregated signals	Developer	12	T-08-01
T-08-03	Build API key management: issue, rotate, revoke partner keys; JWT-based authentication on Intelligence API	Developer	8	T-08-02
T-08-04	Build partner usage analytics dashboard (Admin Portal)	Developer	8	T-08-03
T-08-05	Complete DPIA documentation for Lender Intelligence API; ICO re-identification risk assessment	Technical Advisor / DPO	16	T-08-01

EPIC 9 — W3C DID Credential Migration (Year 2)

Epic Goal	Migrate VerifyMe Global credentials from centralised AWS-hosted profiles to W3C Decentralised Identifiers, enabling individuals to hold their own credentials in digital wallets.
------------------	---

ID	User Story	Acceptance Criteria	Points
US-26	As a VerifyMe Global Certified individual (Amara), I want to hold my verified credential in my digital wallet so that I can present it to any landlord or agent without PropComply being involved in every verification event.	W3C DID credential issued to individual's wallet (Microsoft Authenticator); credential contains: DID, credential type, issuance date, expiry, confidence score band, PropComply issuer DID; verifying	34

ID	User Story	Acceptance Criteria	Points
		agent scans QR and cryptographically verifies without calling PropComply API.	

Task ID	Task	Assignee	Est. Hours	Dependencies
T-09-01	Set up PropComply DID Document on did:web method; publish at /.well-known/did.json	Technical Advisor	8	—
T-09-02	Integrate Trinsic or Aca-Py (ACA-Py Hyperledger Aries) as credential issuance framework	Technical Advisor	24	T-09-01
T-09-03	Build credential issuance endpoint: POST /api/v1/verifyme/{id}/issue-did-credential — generates W3C Verifiable Credential JSON-LD; signs with PropComply private key	Developer	16	T-09-02
T-09-04	Build credential verification endpoint: POST /api/v1/verify/credential — accepts VC JSON-LD; validates issuer DID, signature, expiry; returns result	Developer	10	T-09-03
T-09-05	Build agency QR code scanner: agency users scan individual's wallet QR code; verification result displayed in agency dashboard	Developer	10	T-09-04
T-09-06	Migrate existing Year 1 centralised profiles to DID credentials for consenting individuals	Developer	12	T-09-03

6. Technical Architecture

6.1 Architecture Overview — Three-Tier Modular MVC

PropComply AI is built as a three-tier, MVC-structured application. Each tier is independently deployable and horizontally scalable. The application follows a modular monolith approach for Year 1 MVP (simpler deployment, faster iteration) with a defined migration path to microservices for Year 2 as individual modules grow in complexity and independence.

Tier	Responsibility	Technology	Deployment
Presentation Tier (View)	User interface for agency portal, individual VerifyMe Global app, and admin portal. Responsible for all user-facing interactions, form validation, and state management.	React 18 (TypeScript) + Next.js 14 (App Router) + Tailwind CSS + React Query (data fetching) + Zustand (state)	Vercel (edge) or AWS Amplify; CDN-served; server-side rendering for initial load
Application Tier (Controller/Service)	Business logic, API routing, module orchestration, authentication, external API integration, background job processing. The core of the MVC pattern.	Node.js 20 LTS + Express 5 (API framework) + TypeScript + Bull (queue) + Passport.js (auth) + Zod (validation)	AWS ECS (Fargate) — containerised; Docker; auto-scaling based on CPU/memory; minimum 2 instances at all times
Data Tier (Model)	Persistent data storage (relational), time-series audit data, document storage, cache, and blockchain state.	PostgreSQL 16 (primary relational DB) + Redis 7 (cache + session) + AWS S3 (document/file storage) + Hyperledger Fabric 2.5 (audit chain)	AWS RDS (PostgreSQL — Multi-AZ) + AWS ElastiCache (Redis) + S3 Standard + AWS MSK (Kafka, Year 2)

6.2 Technology Stack — Full Detail

Layer	Technology	Version	Purpose	Rationale
Frontend Framework	Next.js	14 (App Router)	Agency portal, VerifyMe Global individual app, Admin portal	SSR for SEO/performance; React ecosystem; TypeScript support; Vercel deployment integration
Frontend UI	React	18	Component library	Industry standard; large ecosystem; concurrent rendering
Frontend Styling	Tailwind CSS	3.4	Utility-first styling; responsive design	Rapid development; consistent design system; no CSS specificity issues
Frontend State	Zustand	4	Global client state management	Lightweight alternative to Redux; simple API; TypeScript-first

Layer	Technology	Version	Purpose	Rationale
Frontend Data	React Query (TanStack)	5	Server state, caching, background refetch	Eliminates manual cache management; automatic stale-while-revalidate
Frontend Forms	React Hook Form + Zod	7 + 3	Multi-step forms with validation	Performance (uncontrolled); Zod schema reuse between frontend and backend
Backend Runtime	Node.js	20 LTS	Application server runtime	Non-blocking I/O ideal for API-heavy, I/O-bound compliance workloads
Backend Framework	Express	5	HTTP routing and middleware	Mature; minimal; TypeScript compatible; large middleware ecosystem
Backend Language	TypeScript	5.4	Type-safe backend development	Shared types between frontend and backend; catches errors at compile time
Authentication	Passport.js + JWT + TOTP	0.7 / 9 / —	Session management, API auth, MFA	JWT for stateless API auth; TOTP for MFA (speakeasy library); Passport strategies
Background Jobs	Bull (Redis-backed)	4	Async processing: biometric analysis, OCR, email, cron reminders	Redis-backed queue; retries; job prioritisation (Express verification queue)
Email	AWS SES	SDK v3	Transactional email: verification, reminders, SAR notifications	High deliverability; GDPR-compliant EU region available; cost-effective at scale
Primary Database	PostgreSQL	16	All relational data: agencies, individuals, CDD records, risk scores, credentials, consents, audit logs	ACID compliant; JSONB for flexible schema fields; strong GDPR tooling; AWS RDS managed
Cache / Session	Redis	7	Session store, API response cache, Bull job queue, rate limiting	In-memory speed; TTL-based expiry; cluster mode for HA
Document Storage	AWS S3	—	Encrypted document storage: bank statements, passports, CDD files, generated PDFs	Server-side encryption (SSE-S3); versioning; lifecycle policies for GDPR retention
OCR / Document Parse	AWS Textract	—	Bank statement OCR, document text extraction	Managed, scalable; no infrastructure; strong accuracy on financial documents
Biometric	AWS Rekognition (Yr1)	—	Face matching, liveness detection	Managed; no ML infrastructure required; FaceSearch + DetectFaces APIs
Blockchain	Hyperledger Fabric	2.5	Immutable audit trail for all compliance events	Permissioned; enterprise-grade; known by regulators; no cryptocurrency overhead

Layer	Technology	Version	Purpose	Rationale
Payments	Stripe	API v1	Individual profile fees, agency subscriptions, Express Verification	PCI DSS compliant; strong subscription billing; UK payment methods
PSD2 Open Banking	TrueLayer (UK/EU)	v3	EU/EEA bank transaction data retrieval for Elena-type individuals	FCA-authorised; wide EU bank coverage; consent management built-in
PDF Generation	Puppeteer	22	Guarantor Replacement Certificates, CDD reports, audit reports	Full HTML/CSS rendering; pixel-perfect output; runs headless in container
Infrastructure	AWS (eu-west-2 primary)	—	All compute, storage, database; eu-west-2 (London) for UK GDPR data residency	UK data residency; ISO 27001 certified; GDPR DPA in place with AWS
Container Orchestration	AWS ECS Fargate	—	Containerised application tier; auto-scaling	No EC2 management; pay per task; integrates with ECR, ALB, CloudWatch
CI/CD	GitHub Actions	—	Automated testing, build, deploy pipeline	Native GitHub integration; secrets management; Docker build and push to ECR
Monitoring	AWS CloudWatch + Sentry	—	Infrastructure metrics, application error tracking, alerting	CloudWatch for infra; Sentry for application-level error capture and alerting
Secret Management	AWS Secrets Manager	—	API keys (NIBSS, Aadhaar, NCA, Stripe), database credentials, Hyperledger certificates	Automatic rotation; IAM-integrated; audit trail on secret access
CDN	AWS CloudFront	—	Static asset delivery, API edge caching	Global CDN; HTTPS enforcement; WAF integration

6.3 Modular MVC Structure — Application Layer

The application is divided into eight bounded modules. Each module has its own Controller, Service, and Model layers. Modules communicate via well-defined internal service interfaces, not direct database queries across module boundaries.

Module	Controller	Service	Model(s)	External Dependencies
auth	AuthController — handles login, MFA, token refresh, logout	AuthService — JWT generation, TOTP validation, session management, rate limiting	User, Agency, Session, AuditLog	Speakeasy (TOTP), bcrypt (password hash), JWT

Module	Controller	Service	Model(s)	External Dependencies
agency	AgencyController — agency CRUD, user management, plan management	AgencyService — Companies House verification, subscription management, RBAC enforcement	Agency, AgencyUser, Role, Permission, Subscription	Companies House API, Stripe API
aml	AMLController — initiate check, upload documents, retrieve score	AMLService — routing logic, risk scoring, EDD trigger, explainability engine, PEP/sanctions screening	Check, RiskScore, Document, SanctionsResult	Experian API, Equifax API, Comply Advantage, AWS Textract
cdd	CDDController — CDD CRUD, pathway management, file export	CDDService — pathway selection, checklist enforcement, 5-year retention scheduling, deletion workflow	CDDRecord, CDDChecklist, RetentionSchedule	VerifyMe Global Service (cross-module), Hyperledger Service
sar	SARController — SAR CRUD, submission, CTP tracking	SARService — draft generation, NCA API submission, tipping-off enforcement, CTP status tracking	SAR, SAREvent, CTPStatus	NCA SARs Online API, AWS SES (email)
rtr	RTRController — Right to Rent check, reminder management	RTRService — document classification, HMPO integration, share code integration, reminder scheduling	RTRCheck, RTRReminder	HMPO API, UKVI Share Code API, Bull (scheduler), AWS SES
verifyme	VerifyMeController — individual onboarding, credential management, sharing	VerifyMeService — consent management, biometric processing, financial analysis, fusion engine, credential issuance, DID migration (Yr2)	Individual, ConsentRecord, BiometricResult, FinancialBehaviourScore, GovDBResult, VerifyMeCredential, CredentialShare	AWS Rekognition, TrueLayer, NIBSS API, Aadhaar API (Yr2), Stripe, Puppeteer, Hyperledger Service
admin	AdminController — platform management, DSAR handling,	AdminService — agency lifecycle, individual DSAR processing, partner API key	AdminUser, DSARRequest, PartnerKey, PlatformMetric	Hyperledger Service, AWS CloudWatch

Module	Controller	Service	Model(s)	External Dependencies
	partner key management	CRUD, Hyperledger node monitoring		

6.4 Database Schema — Key Entities

All tables stored in PostgreSQL 16 on AWS RDS (Multi-AZ, encrypted at rest with AES-256). Data residency: eu-west-2 (London) for UK GDPR compliance. Row-level security enabled for tenant data isolation.

Table	Key Columns	Purpose	Retention Policy
agencies	id (UUID PK), companies_house_no, legal_name, hmrc_supervisor_ref, mlro_email, plan_tier, plan_status, created_at, updated_at	Agency organisation master record	Retained while active + 6 years post-termination (MLR 2017)
agency_users	id (UUID PK), agency_id (FK), email, password_hash, role_id (FK), mfa_secret_encrypted, mfa_enabled, last_login, is_active, created_at	Agency user accounts with RBAC	Deactivated on departure; retained 5 years for audit
roles	id, name (Admin/MLRO/ComplianceOfficer/StandardUser), permissions (JSONB)	RBAC role definitions and permission matrix	Permanent — system configuration
checks	id (UUID PK), agency_id (FK), initiator_user_id (FK), subject_name_hash, subject_dob_hash, nationality, document_type, transaction_type, routing_decision, created_at	AML/KYC check records. PII hashed — raw PII in encrypted documents table.	5 years from check date (MLR 2017 Reg. 40)
risk_scores	id (UUID PK), check_id (FK), composite_score, risk_tier, sanctions_result, pep_result, top_factors (JSONB), calculated_at, recalculation_trigger	Risk scoring outputs per check	5 years — linked to check retention
documents	id (UUID PK), check_id or individual_id (FK), document_type, s3_key, encryption_key_id, file_hash, upload_at, deleted_at	Encrypted document metadata. File stored in S3 with SSE-S3.	5 years from associated check completion; soft delete with cascade to S3 deletion job
cdd_records	id (UUID PK), check_id (FK), pathway (Standard/EDD/SDD), checklist_status (JSONB),	CDD workflow	5 years from end of business

Table	Key Columns	Purpose	Retention Policy
	mlro_sign_off_user_id, mlro_sign_off_at, completed_at, deletion_scheduled_at	completion records	relationship; deletion_scheduled_at enforced by nightly job
sars	id (UUID PK), check_id (FK), draft_text (encrypted), status (Draft/MLROReview/Submitted/CTCRequested/CTCReceived), nca_reference, submitted_at, ctp_deadline, file_locked	SAR records with NCA submission tracking	7 years (POCA 2002 obligations)
rtr_checks	id (UUID PK), agency_id (FK), check_id (FK), document_type, rtr_status (Unlimited/TimeLimited/NoRTR), document_expiry, check_performed_at, next_check_due, evidence_pdf_s3_key	Right to Rent check records	5 years from tenancy end date
individuals	id (UUID PK), email_hash, nationality, visa_type, brp_number_hash, onboarding_status, profile_built_at, credential_status, credential_expiry, stripe_customer_id, created_at	VerifyMe Global individual records. No raw PII in this table.	Active credential + 12 months; erasure on DSAR unless fraud prevention hold
consent_records	id (UUID PK), individual_id (FK), consent_source (biometric/bank_statements/nibss/aadhaar/home_office/psd2/referral), consented (bool), consent_timestamp, ip_address, consent_form_version, withdrawn_at	Granular consent audit trail — one row per consent event per data source	Retained for life of individual account + 3 years
biometric_results	id (UUID PK), individual_id (FK), liveness_pass (bool), face_match_score, document_match_score, processed_at, biometric_data_deleted_at	Biometric verification results only — no biometric data. Raw biometric processed in-memory and deleted within 60 seconds.	Retained 12 months; no raw biometric ever persisted
financial_behaviour_scores	id (UUID PK), individual_id (FK), source_type (psd2/statements/mobile_money), income_regularity_score, spending_coherence_score, savings_trajectory, anomaly_flags (JSONB), analysis_period_months, analysed_at	Financial behaviour analysis results	Retained for credential validity period + 12 months
gov_db_results	id (UUID PK), individual_id (FK), db_name (nibss/nin/aadhaar/nida), query_timestamp, match_result (bool), confidence_score, result_reference_hash	Government database cross-	Retained for credential validity + 12 months

Table	Key Columns	Purpose	Retention Policy
		check results. Reference hash only — no raw query response stored.	
verifyme_credentials	id (UUID PK), individual_id (FK), composite_score, certification_status (Unverified/Conditional/Certified), score_breakdown (JSONB), issued_at, expires_at, did_credential_id (Yr2), certificate_pdf_s3_key, is_active	VerifyMe Global issued credentials	Active + 13 months; superseded credentials retained 5 years
credential_shares	id (UUID PK), credential_id (FK), agency_id (FK), shared_at, expires_at, revoked_at, viewed_at	Permission records for individual-to-agency credential sharing	Expired + 12 months
hyperledger_events	id (UUID PK), event_type, actor_id_hash, entity_id_hash, block_number, transaction_id, recorded_at	Local index of Hyperledger events for fast querying. Source of truth is on-chain.	Permanent — mirrors blockchain
partner_api_keys	id (UUID PK), partner_name, partner_type (lender/insurer/proptech), api_key_hash, scopes (JSONB), rate_limit_daily, is_active, dpa_signed_at, created_at	Data Intelligence API partner authentication	Active + 7 years (DPA obligation)
audit_logs	id (UUID PK), user_id (FK), action, resource_type, resource_id, ip_address, user_agent, timestamp	Application-level audit log for all user actions. Separate from Hyperledger (finer grain).	24 months (authentication events); 5 years (compliance actions)

7. API Specifications

All APIs are REST, JSON over HTTPS (TLS 1.3). Base URL: <https://api.propcomply.ai/v1>.
Authentication: Bearer JWT for agency users; API key (X-API-Key header) for partner integrations.
Rate limits apply per tier.

7.1 Agency & Auth APIs

Method	Endpoint	Description	Auth	Key Parameters / Response
POST	/auth/register	Register new agency	None	Body: companies_house_no, legal_name, mlro_email, password. Response: agency_id, verification_email_sent
POST	/auth/login	Agency user login	None	Body: email, password, totp_code. Response: access_token (JWT 1hr), refresh_token (7d)
POST	/auth/refresh	Refresh access token	Refresh JWT	Body: refresh_token. Response: new access_token
POST	/auth/logout	Invalidate session	Bearer JWT	Blacklists refresh token in Redis
GET	/agencies/{id}	Get agency details	Bearer JWT (Admin)	Response: agency object with plan, user count, HMRC ref
PUT	/agencies/{id}	Update agency profile	Bearer JWT (Admin)	Body: partial agency fields. Response: updated agency
GET	/agencies/{id}/users	List agency users	Bearer JWT (Admin)	Response: array of user objects with roles
POST	/agencies/{id}/users/invite	Invite new user	Bearer JWT (Admin)	Body: email, role_id. Response: invitation_id, expires_at
DELETE	/agencies/{id}/users/{userId}	Deactivate user	Bearer JWT (Admin)	Sets is_active=false; does not delete audit logs

7.2 AML/KYC Check APIs

Method	Endpoint	Description	Auth	Key Parameters / Response
POST	/checks	Initiate new AML/KYC check	Bearer JWT	Body: subject_name, dob, nationality, doc_type, doc_number, transaction_type, transaction_value. Response: check_id, routing_decision (uk_footprint / verifyme_global)

Method	Endpoint	Description	Auth	Key Parameters / Response
GET	/checks/{id}	Get check details and score	Bearer JWT	Response: check object with risk_score, risk_tier, top_factors, status, edd_triggered
GET	/checks/{id}/score	Get detailed risk score breakdown	Bearer JWT	Response: composite_score, component_scores (credit/sanctions/pep/document/behaviour), top_factors, explainability_text
POST	/checks/{id}/documents	Upload source of funds document	Bearer JWT	Multipart form: file (PDF/JPEG/PNG, max 25MB), document_type. Response: document_id, ocr_status
GET	/checks/{id}/documents/{docId}/ocr	Get OCR extraction result	Bearer JWT	Response: extracted_income, extracted_transactions, coherence_score, anomaly_flags
POST	/checks/{id}/edd	Manually trigger EDD	Bearer JWT (MLRO)	Body: reason. Response: edd_record_id, mlro_notified
POST	/checks/{id}/edd/{eddId}/signoff	MLRO EDD sign-off	Bearer JWT (MLRO)	Body: decision (proceed/refer/sar), notes. Response: signoff recorded, file_unlocked
GET	/checks	List checks for agency	Bearer JWT	Query: status, risk_tier, date_from, date_to, page, limit. Response: paginated check list

7.3 VerifyMe Global APIs

Method	Endpoint	Description	Auth	Key Parameters / Response
POST	/individuals/register	Register individual for VerifyMe Global	None (public)	Body: email, nationality, visa_type. Response: individual_id, onboarding_token
GET	/individuals/{id}/consent	Get consent dashboard state	Individual JWT	Response: array of consent items with consented status per source
POST	/individuals/{id}/consent	Record consent decision	Individual JWT	Body: source, consented (bool), consent_form_version. Response: consent_record_id, timestamp
POST	/individuals/{id}/biometric/liveness	Submit liveness challenge result	Individual JWT	Body: video_token (from AWS Rekognition SDK). Response: liveness_pass,

Method	Endpoint	Description	Auth	Key Parameters / Response
				face_match_score. Biometric data deleted within 60s.
POST	/individuals/{id}/documents	Upload identity document	Individual JWT	Multipart: file, document_type. Response: document_id, mrz_extracted, authenticity_score
POST	/individuals/{id}/bank-statements	Upload bank statements for analysis	Individual JWT	Multipart: files (up to 24 PDF files). Response: analysis_job_id. Async — poll for completion.
GET	/individuals/{id}/bank-statements/{jobId}	Get bank statement analysis result	Individual JWT	Response: income_regularity_score, spending_coherence_score, anomaly_flags, job_status
POST	/individuals/{id}/open-banking	Initiate PSD2 Open Banking consent	Individual JWT	Body: country_code. Response: truelayer_auth_url. Individual redirects to bank.
GET	/individuals/{id}/open-banking/callback	PSD2 callback — retrieve transactions	Individual JWT	Query: code (OAuth code). Exchanges for bank data; triggers analysis. Response: analysis_job_id
POST	/individuals/{id}/gov-db-check	Trigger source-country government database check	Individual JWT	Body: db_name (nibss/nin/aadhaar/nida), reference_number. Response: check_id, status (async)
GET	/individuals/{id}/score	Get current Triple-Source fusion score	Individual JWT	Response: composite_score, certification_status, score_breakdown, components_complete
POST	/individuals/{id}/credentials	Issue VerifyMe Global credential	Individual JWT	Triggered when composite_score ≥ 60. Response: credential_id, status, certificate_pdf_url (if ≥ 80)
GET	/individuals/{id}/credentials/{credId}	Get credential details	Individual JWT	Response: credential object with score, status, issued_at, expires_at

Method	Endpoint	Description	Auth	Key Parameters / Response
POST	/individuals/{id}/credentials/{credId}/share	Share credential with agency	Individual JWT	Body: agency_propcomply_id. Response: share_id, expires_at
DELETE	/individuals/{id}/credentials/{credId}/shares/{shareId}	Revoke agency share	Individual JWT	Sets revoked_at on share record; agency loses access immediately
DELETE	/individuals/{id}	Request erasure (DSAR)	Individual JWT	Triggers DSAR workflow; anonymises PII; retains anonymised event record for fraud prevention; confirmation email sent
POST	/individuals/{id}/credentials/{credId}/issue-did	Issue W3C DID credential (Year 2)	Individual JWT	Response: did_credential_json_id, wallet_deep_link

7.4 Right to Rent APIs

Method	Endpoint	Description	Auth	Key Parameters / Response
POST	/rtr-checks	Initiate Right to Rent check	Bearer JWT	Body: check_id (optional FK to AML check), document_type, document_expiry, share_code (optional). Response: rtr_check_id, rtr_status, next_check_due
GET	/rtr-checks/{id}/evidence	Download Right to Rent evidence PDF	Bearer JWT	Response: signed S3 URL for timestamped evidence PDF
GET	/rtr-checks/upcoming-renewals	Get upcoming Right to Rent renewals	Bearer JWT	Query: days_ahead (default 90). Response: list of RTR checks expiring within window
POST	/rtr-checks/{id}/recheck	Record RTR re-check completion	Bearer JWT	Body: new_document_type, new_expiry. Response: updated rtr_check_id

7.5 SAR APIs

Method	Endpoint	Description	Auth	Key Parameters / Response
POST	/sars	Create SAR draft (auto or manual)	Bearer JWT (MLRO)	Body: check_id, trigger (auto/manual), initial_narrative. Response: sar_id, draft_text, file_locked
PUT	/sars/{id}	Update SAR draft	Bearer JWT (MLRO)	Body: draft_text (full updated text). Response: updated sar

Method	Endpoint	Description	Auth	Key Parameters / Response
POST	/sars/{id}/submit	Submit SAR to NCA	Bearer JWT (MLRO)	Triggers NCA API submission. Response: nca_reference, submitted_at
GET	/sars/{id}/ctp	Get NCA Consent to Proceed status	Bearer JWT (MLRO)	Response: ctp_status, ctp_deadline, ctp_received_at

7.6 Data Intelligence APIs (Year 2 — Partner Access)

Method	Endpoint	Description	Auth	Key Parameters / Response
GET	/intelligence/lender	Query anonymised cross-border financial signals	X-API-Key (Partner)	Query: nationality_band, occupation_band, property_type, date_from, date_to. Response: income_regularity_index, rent_payment_completion_rate, k_anonymity_n (always ≥50), record_count
GET	/intelligence/insurer	Query anonymised tenant risk signals	X-API-Key (Partner)	Query: property_type, source_country_region, tenancy_duration_band. Response: default_rate, deposit_dispute_rate, early_termination_rate, k_anonymity_n
POST	/intelligence/partners	Register new intelligence partner (Admin only)	Admin Bearer JWT	Body: partner_name, partner_type, scopes, rate_limit_daily, dpa_signed_date. Response: api_key (shown once)
DELETE	/intelligence/partners/{id}/api-key	Revoke partner API key	Admin Bearer JWT	Immediate revocation; partner receives 403 on next call

7.7 External API Integrations

External Service	Purpose	Protocol	Authentication	Data Residency / GDPR Note
Companies House API v3	Agency entity verification at registration	REST / JSON	API key (propcomply.ai registered app)	UK data — no personal data of individuals
Experian / Equifax / TransUnion (UK)	UK credit reference data for UK-footprint clients	REST / JSON	OAuth 2.0 client credentials	UK data. ICO-registered credit reference agencies. Lawful basis: Art. 6(1)(b). S.75 Consumer Credit Act notice to subject.
CIFAS API	UK fraud prevention register check	REST / JSON	CIFAS membership credentials	UK data. CIFAS member data sharing agreement. Lawful basis: Art. 6(1)(f).

External Service	Purpose	Protocol	Authentication	Data Residency / GDPR Note
Comply Advantage / Dow Jones World-Check	PEP and sanctions screening	REST / JSON	API key	Global data. DPA in place. Lawful basis: Art. 6(1)(c) — legal obligation.
HMPO Document Checking Service	UK passport validity check	REST / JSON	HMPO API credentials (government-issued)	UK Govt data. Lawful basis: Art. 6(1)(c).
UKVI Share Code Service	Digital immigration status verification	REST / JSON	UKVI API credentials	Home Office data. Lawful basis: Art. 6(1)(c). GDPR exemption for immigration purposes applies.
NCA SARs Online API	SAR submission to UKFIU	SOAP / XML (UKFIU spec)	NCA issued credentials + MLRO certificate	UK law enforcement data. Lawful basis: Art. 6(1)(c). POCA 2002 obligation.
AWS Rekognition	Biometric liveness detection and face matching (Year 1)	AWS SDK	IAM role (ECS task)	Processed in eu-west-2. AWS DPA in place. Biometric data not retained by Rekognition after API call (confirmed in AWS DPA).
AWS Textract	OCR on bank statements and identity documents	AWS SDK	IAM role	Processed in eu-west-2. Data deleted from Textract after processing.
TrueLayer (PSD2)	Open Banking transaction data retrieval for EU/EEA individuals	REST / JSON (OAuth 2.0)	TrueLayer API key + individual OAuth consent	TrueLayer FCA authorised. Data processed EU/UK. DPA in place. Lawful basis: Art. 6(1)(a) — explicit consent.
NIBSS API (Nigeria)	NIN/BVN government database cross-reference for Nigerian nationals	REST / JSON	NIBSS commercial API agreement + PropComply API key	Data transferred from Nigeria to UK: Standard Contractual Clauses (SCCs) in place. NDPR compliance. Lawful basis: Art. 6(1)(a) + Art. 49(1)(a) for international transfer with consent.
Stripe API	Payment processing for individual profiles, agency subscriptions	REST / JSON	Stripe secret key (AWS Secrets Manager)	PCI DSS SAQ A compliant. Stripe EU entity (Ireland). No raw card data in PropComply systems.
AWS SES	Transactional email	AWS SDK	IAM role	Processed eu-west-1. GDPR-compliant. Email addresses are personal data — minimised to necessary communications only.

8. GDPR Compliance Matrix

PropComply AI Ltd acts as Data Controller for all personal data processed through the platform. Agencies using PropComply act as Data Controllers for their own CDD obligations; PropComply acts as Data Processor for agency-instructed processing activities. A Data Processing Agreement (DPA) is signed at agency registration.

8.1 Data Processing Activities Register

Processing Activity	Data Categories	Lawful Basis	Retention	Third Party Transfers	DPIA Required
Agency registration and account management	Agency legal name, MLRO contact details, Companies House number, billing data	Art. 6(1)(b) — Contract performance	Active account + 6 years post-termination	Stripe (billing), AWS (hosting)	No
Agency user authentication and access control	User email, password hash, IP address, login timestamps, MFA secret (encrypted)	Art. 6(1)(b) — Contract	5 years post-deactivation	AWS (hosting)	No
AML/KYC check — UK footprint subject	Subject name, DOB, nationality, document type, credit reference data, CIFAS data, PEP/sanctions data, document files	Art. 6(1)(b) — Contract with agency; Art. 6(1)(c) — MLR 2017 legal obligation	5 years from check completion (MLR 2017 Reg. 40)	Experian/Equifax/TransUnion, CIFAS, Comply Advantage, AWS	No (standard credit reference processing)
AML/KYC check — non-UK subject routed to VerifyMe Global	As above plus VerifyMe Global data (see below)	Art. 6(1)(a) — Individual's explicit consent (layered on Art. 6(1)(b) for agency)	5 years from check	As above plus VerifyMe Global processors	Yes — cross-border special category adjacent processing
VerifyMe Global profile — biometric processing (liveness + face match)	Live facial capture (processed in-memory), face matching against passport	Art. 9(2)(a) — Explicit consent for biometric Special Category data	Result retained 12 months; raw biometric data deleted within 60	AWS Rekognition (DPA in place; data deleted after API call)	Yes — biometric data is Special Category

Processing Activity	Data Categories	Lawful Basis	Retention	Third Party Transfers	DPIA Required
	photo and visa biometric, result (pass/fail, confidence score)		seconds of processing		
VerifyMe Global profile — financial behaviour analysis (bank statements)	24 months of bank transaction data (income, spending, counterparties, geolocation of transactions)	Art. 6(1)(a) — Explicit consent	Analysis result retained for credential validity + 12 months; raw statement files deleted 30 days after analysis	AWS Textract (OCR, data deleted after processing)	Yes — financial data, inference-intensive
VerifyMe Global profile — PSD2 Open Banking	Bank-supplied transaction data (same scope as statements; bank-authenticated)	Art. 6(1)(a) — Explicit consent via PSD2 OAuth flow	Analysis result retained for credential validity + 12 months	TrueLayer (FCA authorised, DPA in place)	Yes — direct bank data access
VerifyMe Global profile — government database check (Nigeria NIBSS/NIN/BVN)	NIN number, BVN number, NIBSS identity match result	Art. 6(1)(a) — Explicit consent. International transfer: Art. 49(1)(a) — explicit consent for transfer to Nigeria	Result retained for credential validity + 12 months	NIBSS Nigeria (SCCs executed)	Yes — international transfer to non-adequate country
VerifyMe Global — Home Office visa anchor	BRP number, visa type, visa expiry — queried against HMPO service	Art. 6(1)(a) — Consent; Art. 6(1)(c) — Right to Rent legal obligation	Retained for credential validity + 12 months	HMPO (UK government)	No — standard immigration check
VerifyMe Global credential issuance and sharing	Credential ID, confidence score, certification status, share permissions (agency ID	Art. 6(1)(b) — Contract with individual; Art. 6(1)(a) for voluntary sharing	Credential retained active + 13 months; shares retained expired + 12 months	AWS (hosting); agency (recipient of share — as Controller for their own compliance use)	No — credential is minimal personal data

Processing Activity	Data Categories	Lawful Basis	Retention	Third Party Transfers	DPIA Required
	+ timestamp)				
Anonymised aggregate data intelligence (lender/insurer API)	Aggregated statistical signals — not personal data post-anonymisation (k-anonymity $k \geq 50$, ICO standard tested)	Art. 6(1)(f) — Legitimate interests (once anonymisation confirmed). Note: if re-identification risk exists, this becomes personal data and basis reverts to Art. 6(1)(a).	Aggregated outputs retained 24 months; underlying anonymisation pipeline retested quarterly	Partner lenders/insurers (DPA required; no PII transferred)	Yes — pre-launch DPIA required to confirm anonymisation standard
Partner referral programme (banking/remittance)	Individual name, email, phone (consented referral data only)	Art. 6(1)(a) — Explicit opt-in consent at VerifyMe Global onboarding (separate toggle from profile consent)	Referral data transmitted at point of referral; PropComply retains referral event record 12 months; partner retains per their own privacy policy	Partner banks, remittance providers (DPA + data sharing agreement)	No — if consent is properly granular
Hyperledger audit trail	Actor ID hash, entity ID hash, event type, timestamp, block hash — no raw PII on-chain	Art. 6(1)(c) — Legal obligation (MLR 2017 audit requirements); Art. 5(2) — Accountability principle	Permanent (blockchain immutability); local index 7 years	None — on-chain data is PropComply-controlled nodes	No — hashed data is not personal data
Application audit logs	User ID, action, resource type, resource ID, IP address, user agent, timestamp	Art. 6(1)(b) — Contract (security obligation); Art. 6(1)(f) — Legitimate interests (fraud prevention)	Authentication events: 24 months. Compliance actions: 5 years.	None	No

8.2 Data Subject Rights Implementation

Right	Scope	Implementation	Timeline SLA
Art. 15 — Right of Access (DSAR)	Individuals (VerifyMe Global users); agency users (PropComply account data); client subjects (via agency MLRO)	Individuals: in-app data export button generates JSON of all personal data held. Agency users: Admin Portal DSAR handler generates export. MLROs: CDD file export per subject.	30 days from verified request
Art. 16 — Right to Rectification	Incorrect personal data	Individual can update profile data via VerifyMe Global app (non-verified fields). Verified fields require re-verification. Agency user data correctable by Admin.	Without undue delay; max 30 days
Art. 17 — Right to Erasure	Individuals: VerifyMe Global profile deletion. Agency users: account deactivation.	Individual: DELETE /api/v1/individuals/{id} — PII deleted; anonymised event record retained for fraud prevention (Art. 17(3)(e) exemption). Agency user: deactivation preserves audit logs (legitimate interest override).	30 days; fraud prevention retention documented and disclosed in privacy notice
Art. 18 — Right to Restriction	Processing restricted pending accuracy dispute or objection	Admin flag on individual/check record: processing_restricted=true. Automated checks paused. Manual review triggered.	Without undue delay
Art. 20 — Right to Data Portability	Structured, machine-readable format for data provided by the individual	VerifyMe Global profile export in JSON-LD format (compatible with W3C DID ecosystem). Includes: consent records, financial behaviour scores, credential history.	30 days
Art. 21 — Right to Object	Object to processing based on legitimate interests	Objection form in VerifyMe Global app and agency portal. Triggers review by DPO/Technical Advisor. Processing halted pending review.	Without undue delay; response within 30 days
Art. 22 — Right re Automated Decision-Making	Significant decisions based solely on automated processing	Risk score and VerifyMe Global certification are flagged as automated decisions. Individual shown plain-language explanation. Human review available on request (MLRO or PropComply DPO). Art. 22(3) safeguards implemented.	Human review initiated within 5 business days of request

8.3 Privacy by Design Controls

- Data minimisation: only data fields necessary for the specific verification purpose are collected. Each database check collects only the minimum result (match/no-match + confidence score), not full record retrieval.
- Purpose limitation: data collected for VerifyMe Global profile verification is not reprocessed for marketing, profiling beyond the verification purpose, or onward disclosure without fresh consent.
- Pseudonymisation: subject names and document numbers are hashed (SHA-256 + salt) in the checks table. Raw PII is stored only in encrypted documents (S3 SSE-S3) with access logged.

- Encryption at rest: AWS RDS PostgreSQL encrypted with AWS KMS. S3 buckets encrypted with SSE-S3. Redis encryption at rest enabled. TLS 1.3 in transit.
- Biometric data: processed in-memory only using AWS Rekognition. PropComply does not store any biometric data. The deletion timestamp (biometric_data_deleted_at) is recorded in the biometric_results table as evidence of deletion.
- Consent granularity: individual consents are per-data-source, revocable, and timestamped. Consent withdrawal does not affect the lawfulness of prior processing.
- Data residency: all personal data stored in AWS eu-west-2 (London). International transfers to Nigeria (NIBSS) governed by Standard Contractual Clauses and individual explicit consent under Art. 49(1)(a).
- DPIA schedule: DPIAs completed pre-launch for biometric processing, overseas government database checks, and data intelligence API. Annual review thereafter. DPIA register maintained by Technical Advisor.

9. Non-Functional Requirements

Category	Requirement	Target	Measurement
Performance	API response time for risk score calculation	<30 seconds end-to-end (including external API calls)	AWS CloudWatch P95 latency metric
Performance	API response time for standard endpoints (CRUD)	<200ms P95	CloudWatch / Sentry
Performance	VerifyMe Global biometric liveness result	<5 seconds from challenge completion	AWS Rekognition latency metric
Performance	Bank statement OCR processing	<90 seconds per 24-month statement set	Bull queue job duration
Performance	Standard credential issuance	<4 hours from all data submitted	credential.issued_at — onboarding.completed_at
Performance	Express credential issuance	<48 hours	As above; priority queue
Availability	Agency portal and API uptime	99.9% monthly (8.7 hours max downtime/year)	AWS CloudWatch uptime alarm; Pingdom external check
Availability	VerifyMe Global individual app uptime	99.9% monthly	Same as above
Scalability	Concurrent agency users	500 concurrent without degradation (Year 1)	Load test with k6; ECS auto-scaling target
Scalability	VerifyMe Global concurrent onboarding sessions	100 concurrent biometric sessions (Year 1)	AWS Rekognition throughput provisioned
Security	Authentication brute force protection	Account locked after 5 failed attempts; 15-minute lockout; CAPTCHA after 3 attempts	Passport.js rate limiting middleware; Redis counter
Security	API rate limiting	Agency API: 1,000 requests/hour per agency. Partner Intelligence API: configurable per partner (default 500/day).	Express rate-limit middleware; Redis sliding window
Security	Penetration testing	Annual external penetration test by CREST-accredited firm; critical findings remediated within 72 hours	Penetration test report; remediation ticket closure
Security	ISO 27001 alignment	Information security management aligned with ISO 27001 controls. Formal certification target: Year 2.	Internal audit against Annex A controls

Category	Requirement	Target	Measurement
Compliance	PCI DSS	SAQ A level (no card data in PropComply systems; Stripe hosted fields used)	Annual PCI DSS self-assessment
Compliance	UK GDPR	Full compliance per Section 8 of this document	Annual DPIA review; ICO registration current
Disaster Recovery	RTO (Recovery Time Objective)	4 hours	DR runbook; annual DR test
Disaster Recovery	RPO (Recovery Point Objective)	1 hour (AWS RDS automated backups every 5 minutes; point-in-time recovery)	RDS backup configuration
Accessibility	Agency and individual web portals	WCAG 2.1 AA compliance	axe-core automated scan in CI/CD pipeline; manual audit at launch

10. Definition of Done & Acceptance Criteria Standards

A User Story is considered Done when all of the following are true:

1. Code is written, reviewed (minimum 1 peer review), and merged to the main branch via pull request.
2. Unit tests written with minimum 80% coverage for new code in the changed module.
3. Integration tests pass for all external API interactions (mocked in CI; validated against sandbox in staging).
4. GDPR checklist completed: lawful basis confirmed, consent mechanism tested, retention rule implemented, data subject right endpoint (if applicable) tested.
5. Hyperledger event written for all compliance events introduced by the story (if applicable).
6. Security checklist: input validation (Zod schema), SQL injection protection (parameterised queries via Prisma ORM), XSS prevention (React default escaping + DOMPurify where needed), CSRF protection (SameSite cookie + CSRF token).
7. Documentation updated: API endpoint documented in OpenAPI 3.1 spec; module README updated; GDPR register updated if new processing activity introduced.
8. Deployed to staging environment; product owner (Joy Ladegbaye) has reviewed and confirmed acceptance criteria met.
9. Performance: endpoint response time tested and within NFR targets.
10. Accessibility: no new WCAG 2.1 AA violations introduced (axe-core scan passes in CI).

10.1 Sprint Structure

Sprint	Duration	Focus	Target Release
Sprint 0	2 weeks	Infrastructure setup: AWS environment, GitHub Actions CI/CD, PostgreSQL RDS, Redis, S3 buckets, Hyperledger Fabric nodes, DNS, TLS certificates, Secrets Manager	Infrastructure ready
Sprints 1-2	4 weeks	Epic 1: Agency auth, onboarding, RBAC. Epic 7: Dashboard skeleton.	Agency accounts functional
Sprints 3-5	6 weeks	Epic 2: AML/KYC engine (UK footprint). Epic 4: Right to Rent. Epic 5: SAR filing.	Agency core compliance live
Sprints 6-9	8 weeks	Epic 3: VerifyMe Global individual onboarding (consent, biometric, bank statements, NIBSS). Epic 6: Hyperledger integration.	VerifyMe Global MVP live
Sprints 10-11	4 weeks	Integration: VerifyMe Global → Agency routing. Guarantor certificate. Stripe billing. Beta launch 50 individuals + 5 agencies.	Beta launch
Sprints 12-14	6 weeks	Stabilisation, performance testing, security audit, GDPR audit, penetration test. Commercial launch preparation.	Commercial launch (Month 12)
Year 2 — Phase 1	Quarter 1	Epic 8: Data Intelligence API. DPIA completion. Partner onboarding.	Lender Intelligence API beta
Year 2 — Phase 2	Quarter 2-4	Epic 9: W3C DID migration. Federated learning foundation. EU Open Banking.	DID credentials live

10.2 Version Control & Branching Strategy

- Main branch: production-ready code only. Protected. Requires PR with 1 approval and all CI checks passing.
- Develop branch: integration branch for completed features. Deployed to staging automatically.
- Feature branches: feature/{epic-id}/{story-id}-{short-description}. e.g., feature/epic3/us09-consent-dashboard
- Hotfix branches: hotfix/{date}-{description}. Merged directly to main and back-merged to develop.
- Release tags: semantic versioning (v1.0.0, v1.1.0). Tag on every production deployment.

